

The background of the poster is a collage of the main cast members' faces, tinted in a dark blue color. In the center-right, there is a glowing, mechanical figure that appears to be a robot or a high-tech character, with a small, colorful, bird-like headpiece. The figure is emitting a bright purple and blue light. On the right side, a man wearing a white headband with the word 'COMBAT' on it is visible, smiling and making a peace sign. The title 'I KNOW WHAT YOU DID LAST SUMMER' is written in a large, white, serif font across the bottom. To the right of the title, there is a large, stylized red number '3' with a red 'X' mark on it.

I KNOW
WHAT YOU DID
LAST SUMMER 3

about me

some call me a one trick pony, others call me passionate



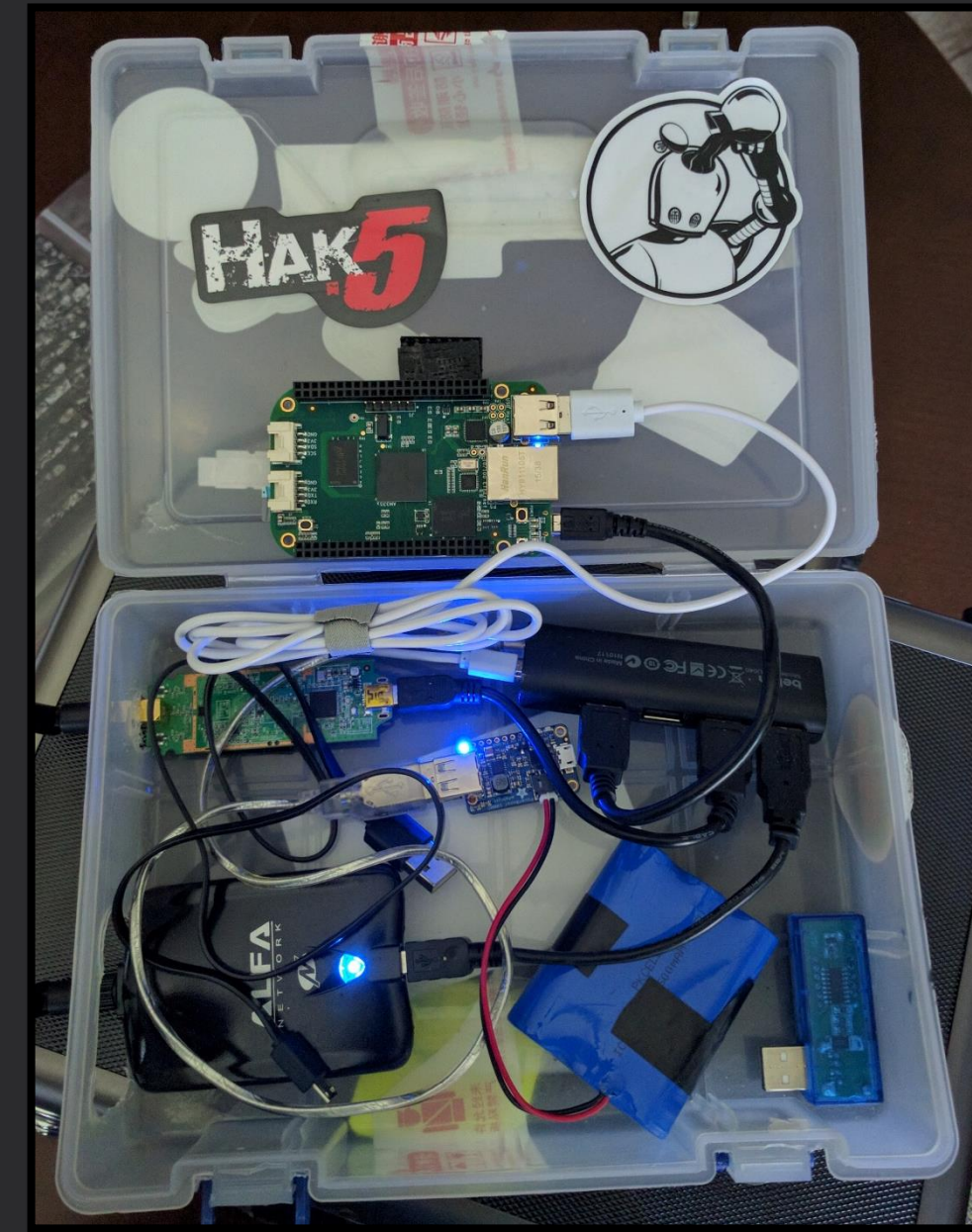
- mad scientist hacker who likes to meddle with hardware and software.
- particularly obsessed with wireless.
- degree in computer science from Southern Utah University
- loves include:
 - web application pentesting
 - wireless monitoring and tracking
 - reverse engineering
- creator of the #WiFiCactus
- Kismet cultist
- Runner

history background

2000

Wardriving got popular in the early 2000's as a way for people to find open networks to piggyback on [1]. Equipment was pretty expensive and limited.

The number of devices that are connected over wireless has increased exponentially since the early 2000's and make Wardriving, Netstumbling and Wireless Monitoring more exciting than ever.



2015

Backpack Test Project

Warwalking with a single-board computer in my backpack for Defcon 23. Collected data on 2 channels at a time.

2016

Project Lana

Planted 12 monitoring boxes around the conference for Defcon 24. 48 total wireless radios scanning at the same time.

2017+

#WiFiCactus

25 Hak5 Pineapple Tetras that cover 50 total channels in 2.4 and 5 GHz. Over 3 hours of battery life. Weighs ~35 lbs.

[1] <https://en.wikipedia.org/wiki/Wardriving>

WiFiCactus

but why though?

Understand the FUD

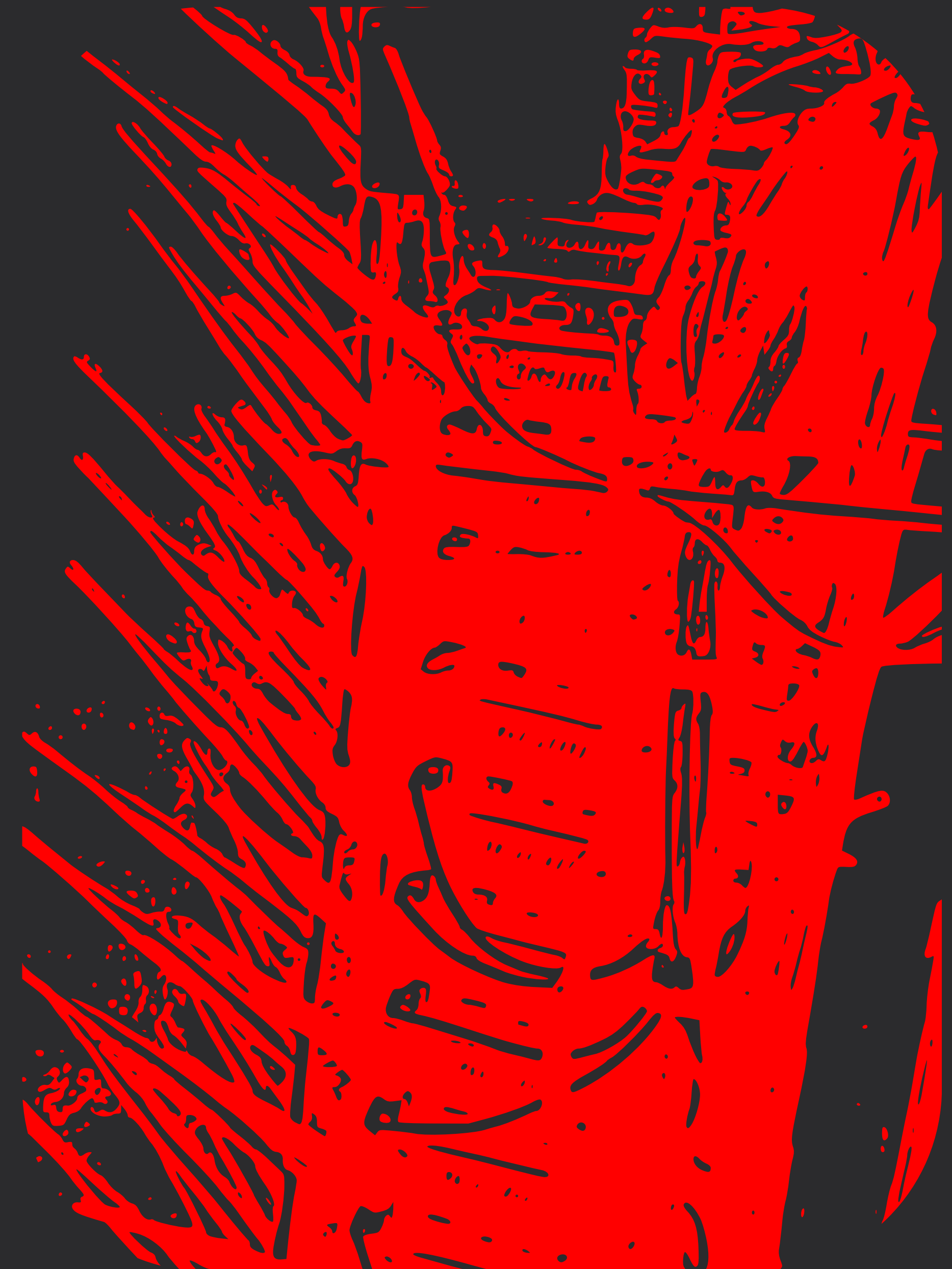
Nearly every person has heard that DEFCON's network is the most dangerous in the world. I wanted to know why and how it is so dangerous. Understanding is the first step to protecting yourself.

The Connected World

Everything is connected now and usually with more than 1 radio. This makes for amazing data. Whether it's your phone's mobile hotspot to the 'SMART' THINGS (IoT) need to be connected and we gotta catch them all!

Verify Then Trust

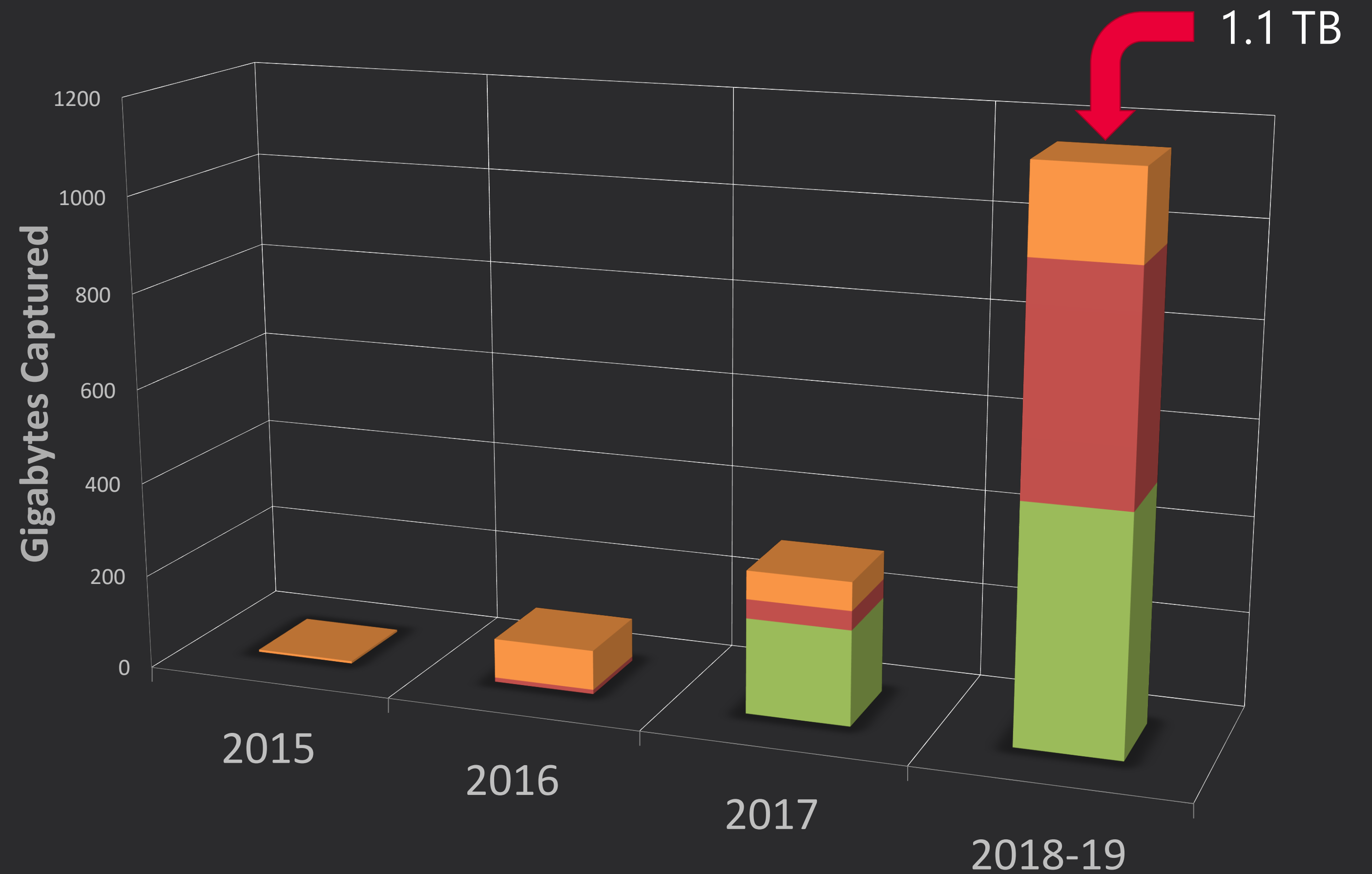
Do you trust that security, software and API's are being done correctly when communicating over a network? Do you know if your favorite app uses encryption? By scanning yourself you can verify how secure things are.



data captured

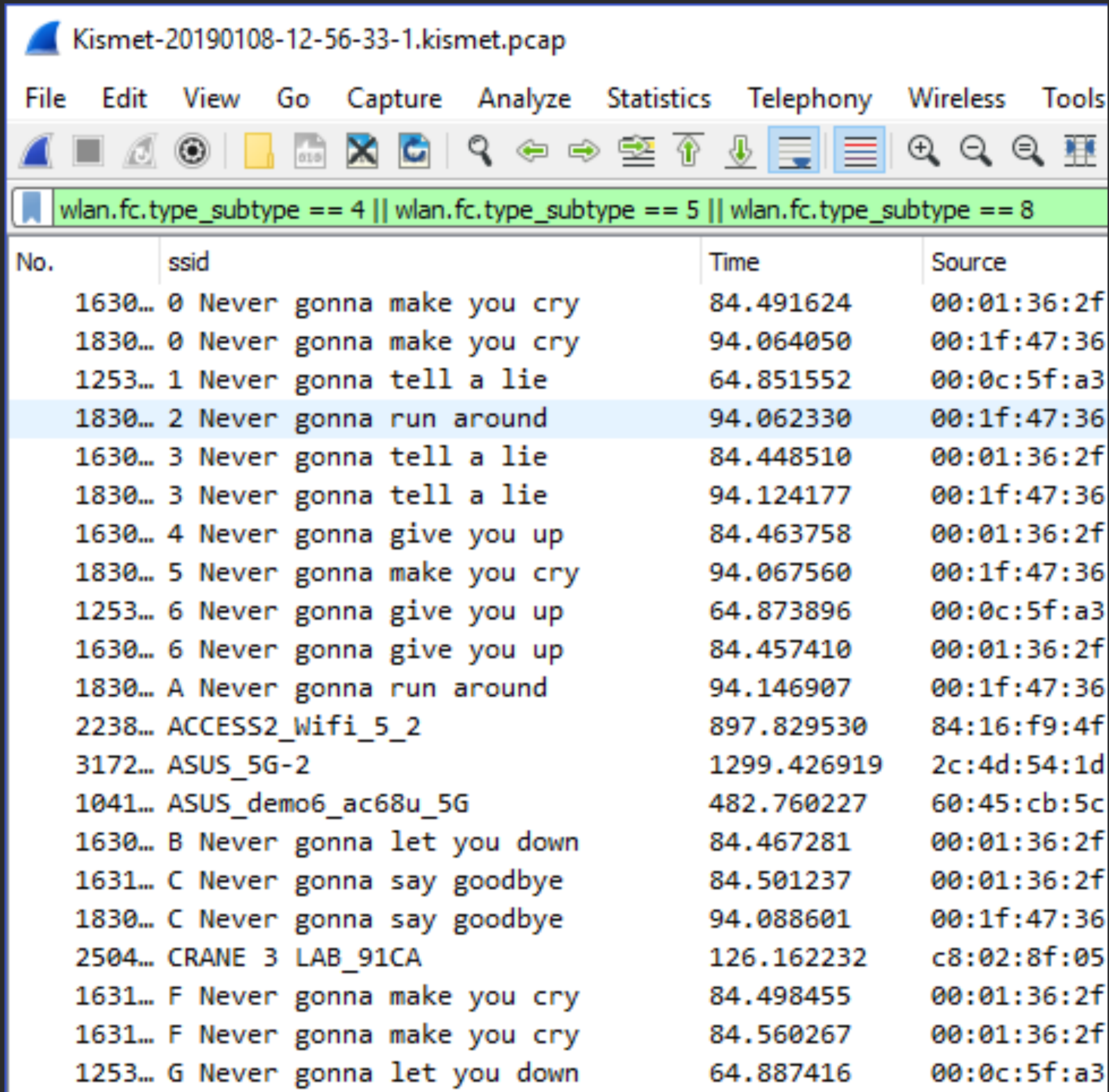
got data?

- 1 DEFCON**
Year by year captured data at DEFCON
- 2 BLACKHAT**
Year by year captured data at Blackhat
- 3 Other Places**
Captures at DC China, DefCamp, SaintCon, CactusCon, Shmoocon and more



how'd you do analysis?

sometimes you have a tool and sometimes you build a tool



Kismet-20190108-12-56-33-1.kismet.pcap

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools

wlan.fc.type_subtype == 4 || wlan.fc.type_subtype == 5 || wlan.fc.type_subtype == 8

No.	ssid	Time	Source
1630...	0 Never gonna make you cry	84.491624	00:01:36:2f
1830...	0 Never gonna make you cry	94.064050	00:1f:47:36
1253...	1 Never gonna tell a lie	64.851552	00:0c:5f:a3
1830...	2 Never gonna run around	94.062330	00:1f:47:36
1630...	3 Never gonna tell a lie	84.448510	00:01:36:2f
1830...	3 Never gonna tell a lie	94.124177	00:1f:47:36
1630...	4 Never gonna give you up	84.463758	00:01:36:2f
1830...	5 Never gonna make you cry	94.067560	00:1f:47:36
1253...	6 Never gonna give you up	64.873896	00:0c:5f:a3
1630...	6 Never gonna give you up	84.457410	00:01:36:2f
1830...	A Never gonna run around	94.146907	00:1f:47:36
2238...	ACCESS2_Wifi_5_2	897.829530	84:16:f9:4f
3172...	ASUS_5G-2	1299.426919	2c:4d:54:1d
1041...	ASUS_demo6_ac68u_5G	482.760227	60:45:cb:5c
1630...	B Never gonna let you down	84.467281	00:01:36:2f
1631...	C Never gonna say goodbye	84.501237	00:01:36:2f
1830...	C Never gonna say goodbye	94.088601	00:1f:47:36
2504...	CRANE 3 LAB_91CA	126.162232	c8:02:8f:05
1631...	F Never gonna make you cry	84.498455	00:01:36:2f
1631...	F Never gonna make you cry	84.560267	00:01:36:2f
1253...	G Never gonna let you down	64.887416	00:0c:5f:a3

Traditional Network Tools

Wireshark and Networkminer were instrumental in providing summery information from the PCAP data. Great for spot checking the data.

Kismet WebUI and KismetDB

Awesome for real-time analytics about what is happening. Additionally helpful to reload KismetDB files after the fact to relive the fun. KismetDB's are SQLITE DBs which enables easy querying.

PCAPinator

Built a custom Python 3 tool that leverages Wireshark's command line tools like tshark by using parallel processing on very large PCAP file datasets. Has a lot of custom output types like CSV, HCCX, etc.



PCAPINATOR

PCAPS OR IT DIDN'T HAPPEN?

JUDGEMENT DAY



pcapinator

a tool to run a lot of tsharks

```
usage: pcapinator.py [-h] --in INFILE [--kismetdb] [--out OUTFILE] [-v] [-d]
                    [--timed] [--split] [--split_count SPLIT_COUNT]
                    [--split_output SPLIT_OUTPUT] [--wshark_dir WSHARK_DIR]
                    [--handshakes] [--wifi_csv] [--hashcat] [--dnsSimple]
                    [--pcapfix] [--pcapfix_dir PCAPFD]
                    [--min_split MINSPLITSZ] [--query TSHARK_QUERY]
                    [--fields TSHARK_FIELDS] [--unique_existing_tsv]
                    [--validate_wifi_tsv]
```

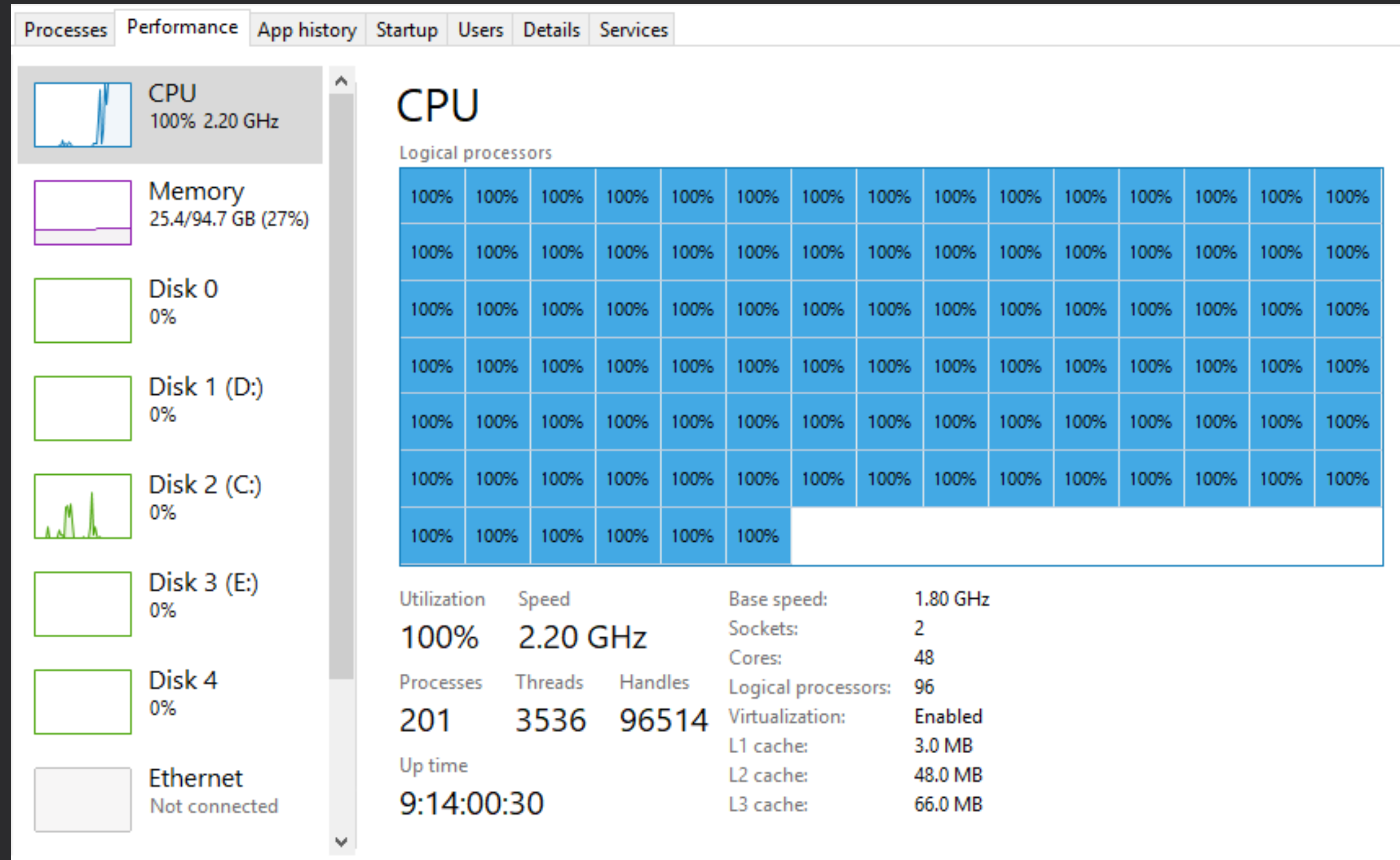
PCAPinator - Tool for crazy PCAP analysis

optional arguments:

-h, --help	show this help message and exit
--in INFILE	Input PCAP file or directory
--kismetdb	Extract PCAP files from Kismet DB
--out OUTFILE	Output file
-v, --verbose	Enable verbose mode
-d, --debug	Enable debugging output
--timed	Return the processing time of each portion of the code
--split	Split the PCAP into pieces based on CPU count
--split_count SPLIT_COUNT	Set the number of pieces the PCAP will be split into
--split_output SPLIT_OUTPUT	Directory location of the newly split files
--wshark_dir WSHARK_DIR	Define the location of the wireshark directory
--handshakes	Get WPA/WPA2 handshakes
--wifi_csv	Build CSV files with default tables
--hashcat	Output to Hashcat format
--dnsSimple	Create a CSV of dns data only
--pcapfix	Fixes Borked PCAP files, only works in *nix
--pcapfix_dir PCAPFD	Set the PCAPFix directory where broken files will go
--min_split MINSPLITSZ	Min Split Size in bytes, default 200 MB
--query TSHARK_QUERY	A custom query that you want to run on a dataset, use with --fields
--fields TSHARK_FIELDS	The fields list you would like to use with your query, use with --query
--unique_existing_tsv	Get unique data from an existing TSV file
--validate_wifi_tsv	Validate and fix a tsv file you are making

a tool to run a lot of tsharks

Name	Status	CPU	Memory	Disk
tshark		0.4%	78.5 MB	0.3 MB/s
tshark		0.5%	79.4 MB	0.4 MB/s
tshark		0.4%	77.8 MB	0.4 MB/s
tshark		0.3%	76.2 MB	0.3 MB/s
tshark		0.4%	76.0 MB	0.4 MB/s
tshark		0.5%	79.1 MB	0.4 MB/s
tshark		0.4%	78.7 MB	0.4 MB/s
tshark		0.4%	82.6 MB	0.4 MB/s
tshark		0.5%	78.2 MB	0.4 MB/s
tshark		0.4%	79.3 MB	0.4 MB/s
tshark		0.4%	76.7 MB	0.3 MB/s
tshark		0.4%	78.3 MB	0.4 MB/s
tshark		0.4%	77.7 MB	0.3 MB/s
tshark		0.5%	77.6 MB	0.4 MB/s
tshark		0.5%	75.7 MB	0.4 MB/s



```
r: /mnt/e/pcapinator/split_Kismet-20180809-13-37-09-1_0004
f: /mnt/e/pcapinator/split_Kismet-20180809-13-37-09-1_0004
f: /mnt/e/pcapinator/split_Kismet-20180809-13-37-09-1_0004
f: /mnt/e/pcapinator/split_Kismet-20180809-13-37-09-1_0004
f: /mnt/e/pcapinator/split_Kismet-20180809-13-37-09-1_0004
f: /mnt/e/pcapinator/split_Kismet-20180809-13-37-09-1_0004
f: /mnt/e/pcapinator/split_Kismet-20180809-13-37-09-1_0004
f: /mnt/e/pcapinator/split_Kismet-20180809-13-37-09-1_0004
f: /mnt/e/pcapinator/split_Kismet-20180809-13-37-09-1_0004
---- Ran pcapinator: 15803.595164299011 Seconds ----
```


DEMO VIDEO

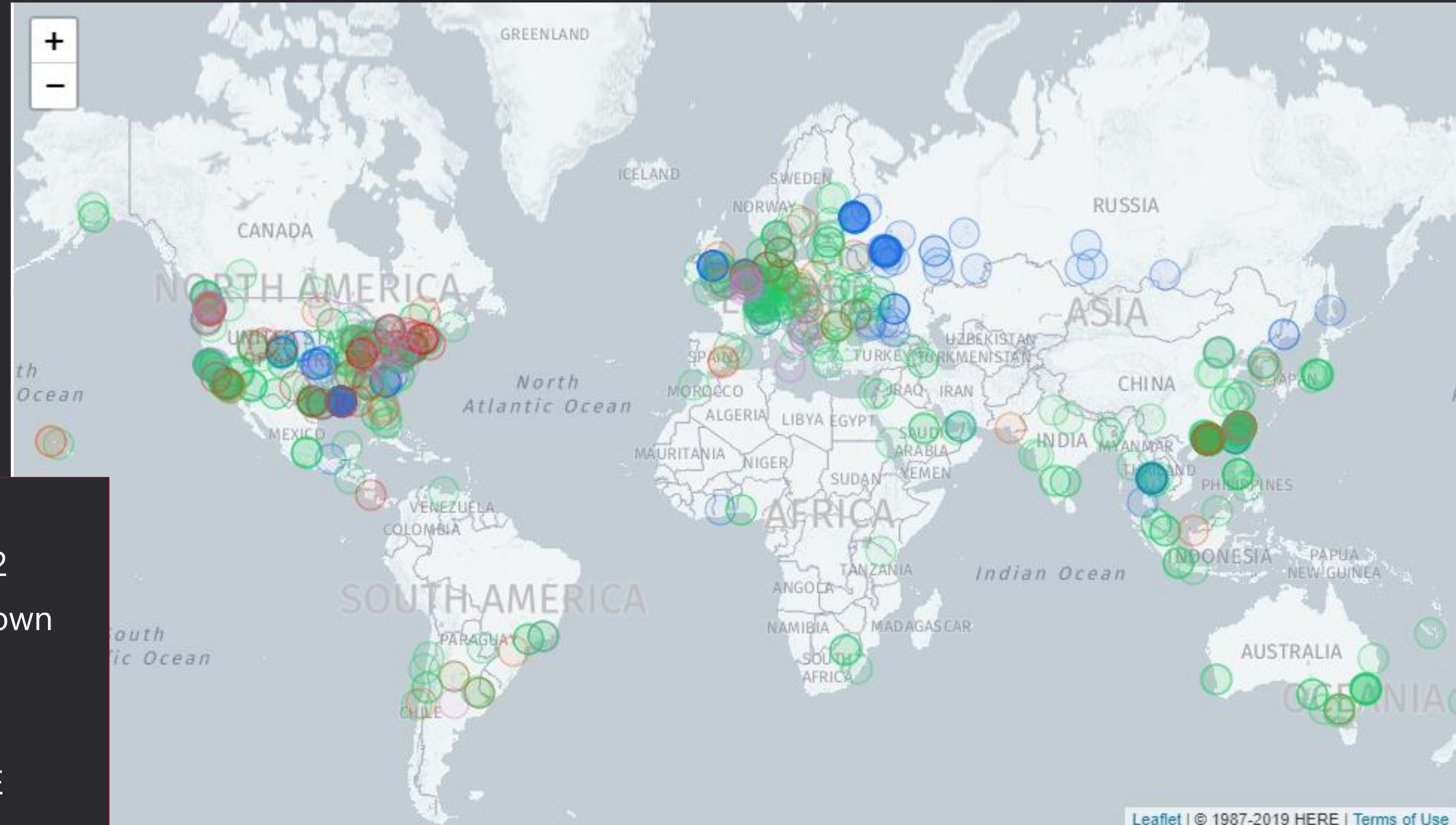
SO WHAT DID YA'LL
DO LAST SUMMER?

getting to know you

where are you from?

Probes and WIGLE.net

This info is based on probe requests captured during DEFCON and then searching those using the Wigle API.

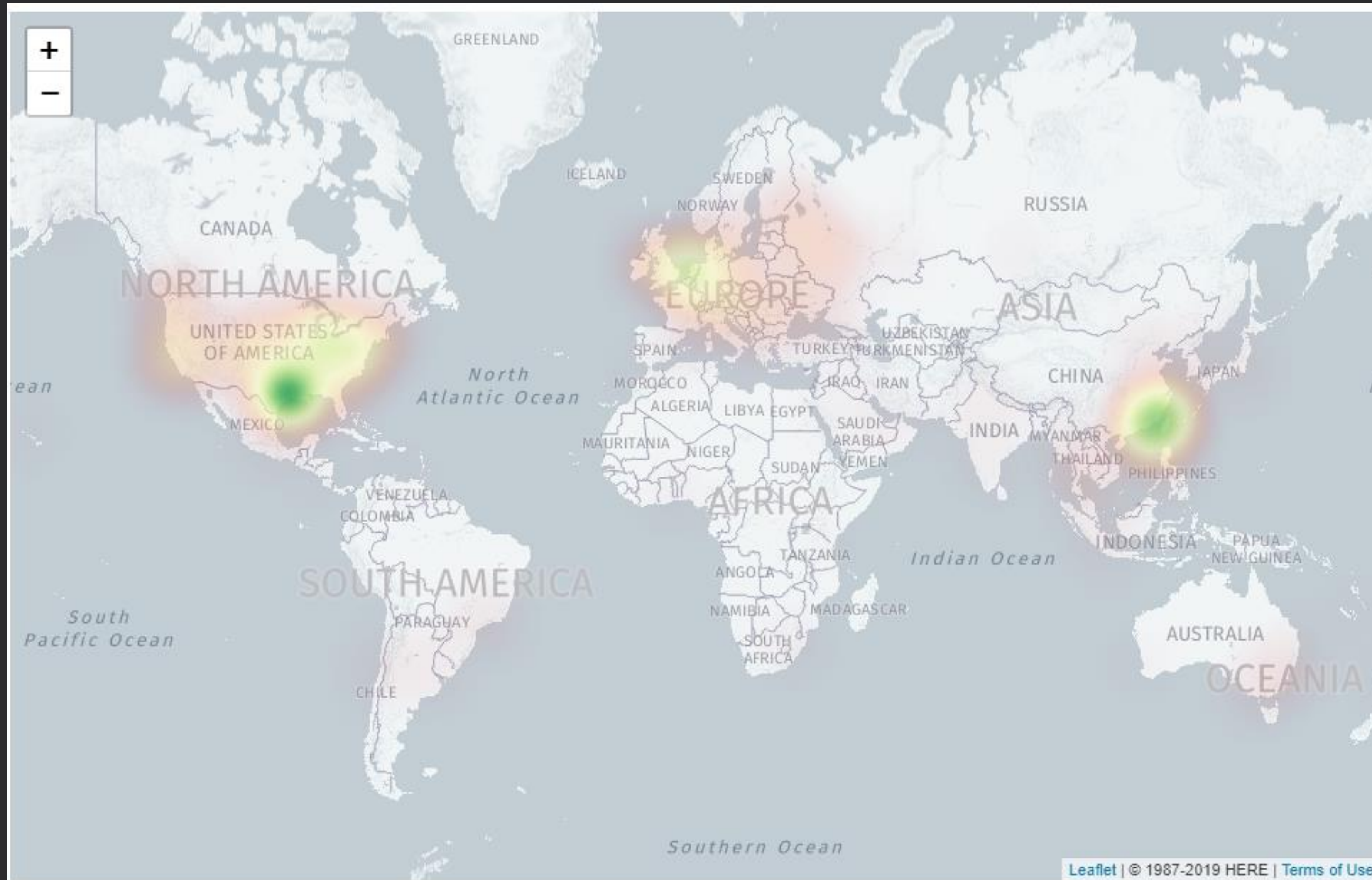


getting to know you

where are you from?

Probes and WIGLE.net

This info is based on probe requests captured during DEFCON and then searching those using the Wigle API.

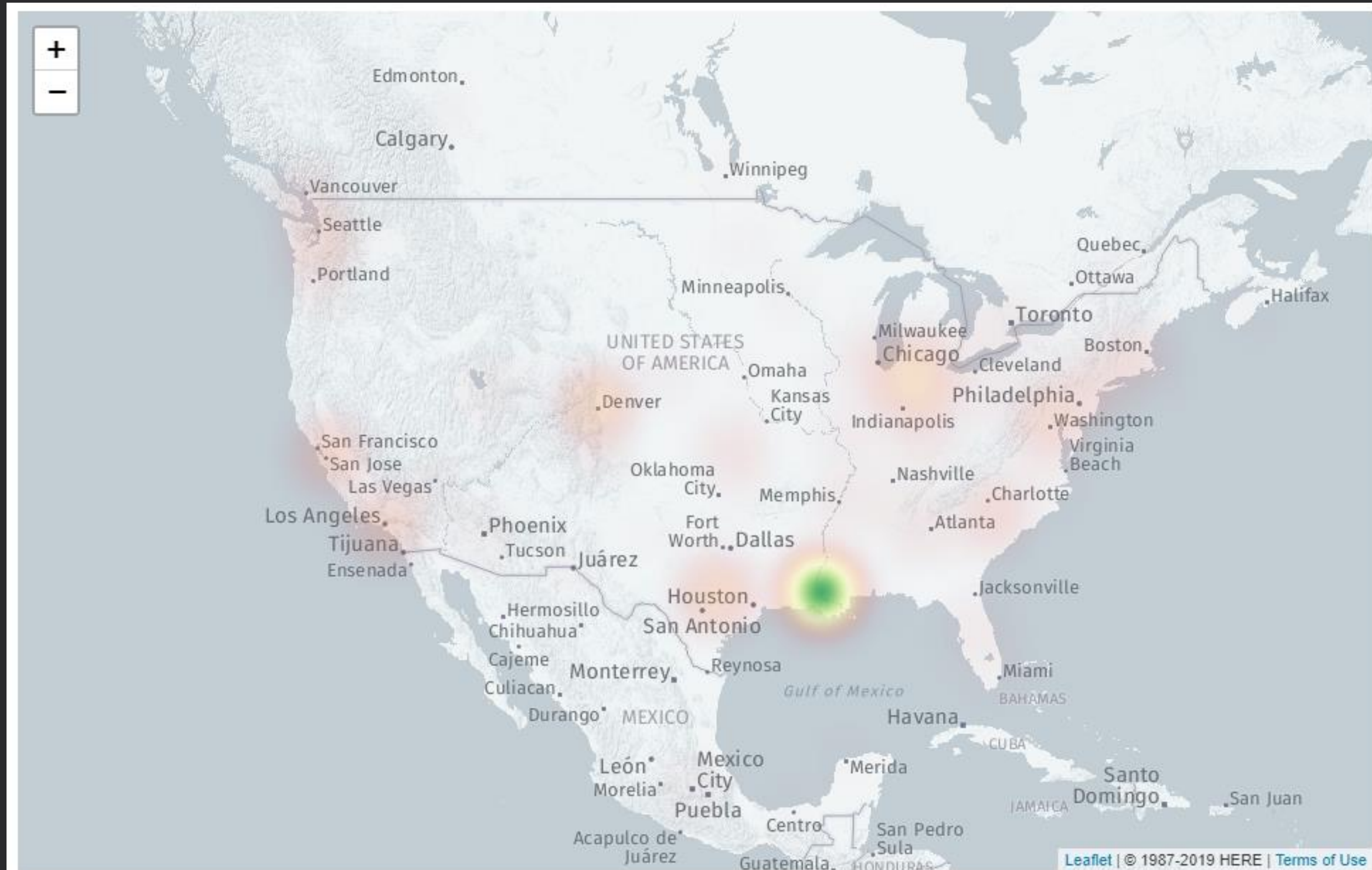


getting to know you

where are you from?

Probes and WIGLE.net

This info is based on probe requests captured during DEFCON and then searching those using the Wigle API.

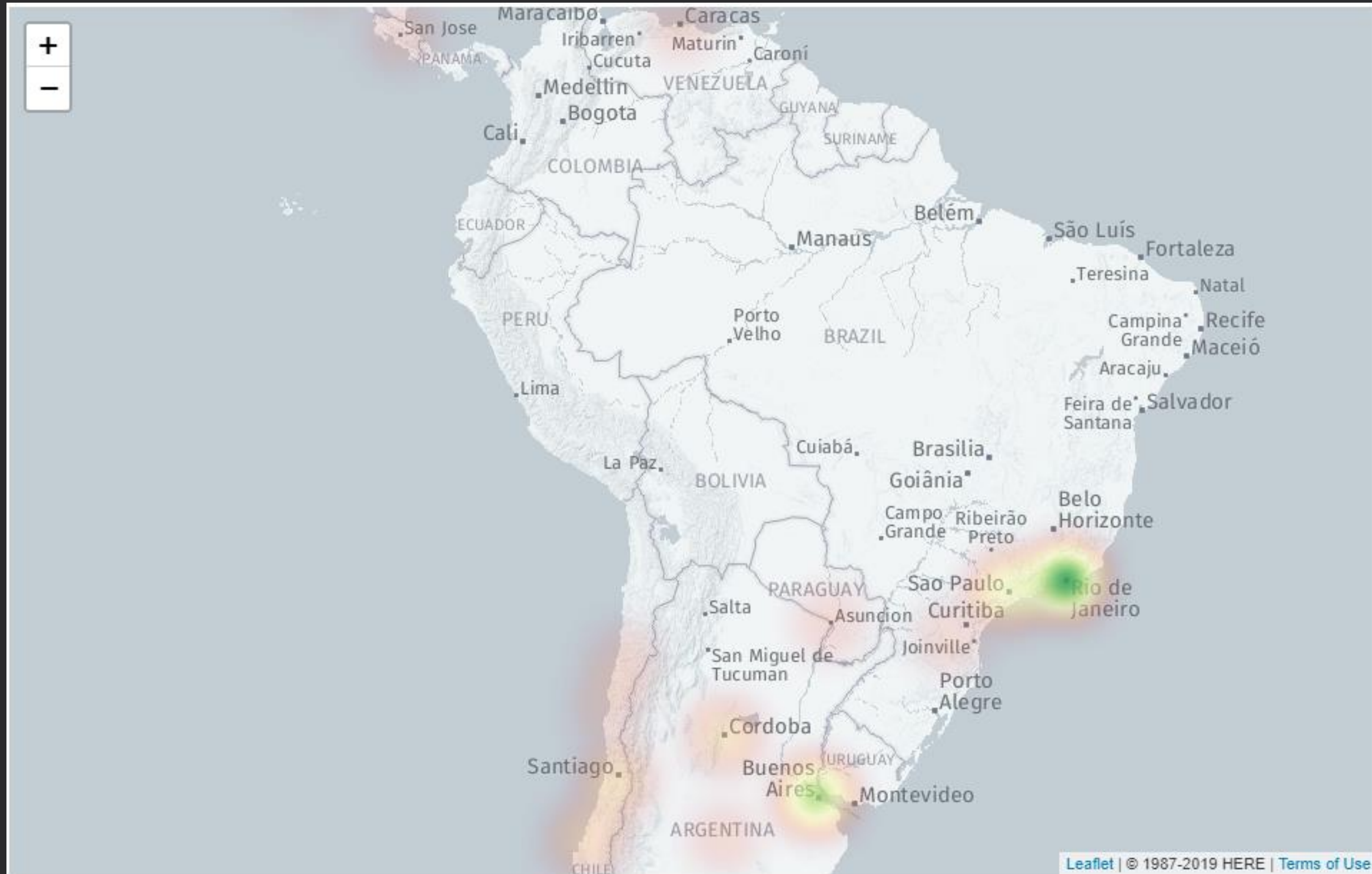


getting to know you

where are you from?

Probes and WIGLE.net

This info is based on probe requests captured during DEFCON and then searching those using the Wigle API.

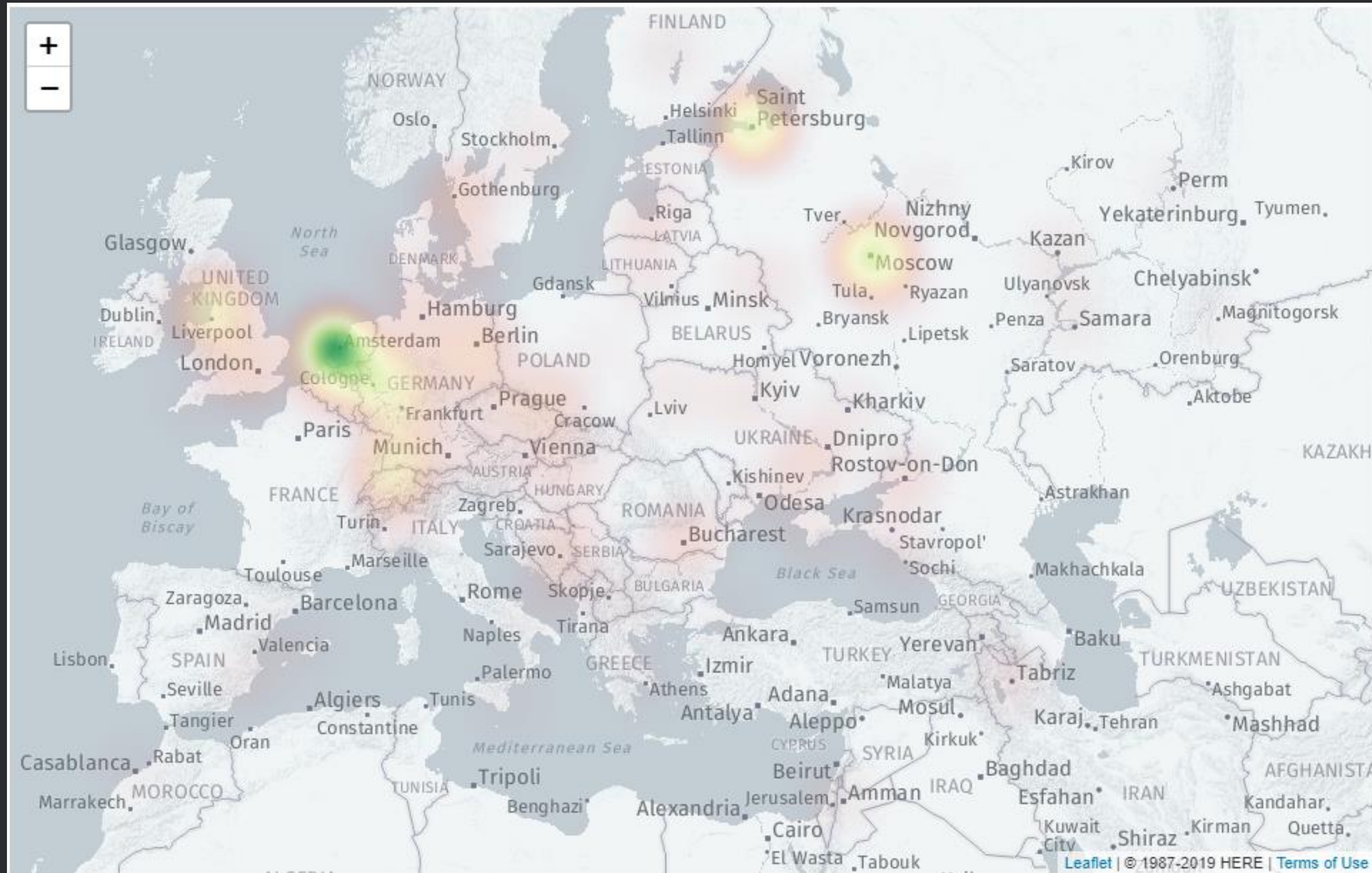


getting to know you

where are you from?

Probes and WIGLE.net

This info is based on probe requests captured during DEFCON and then searching those using the Wigle API.

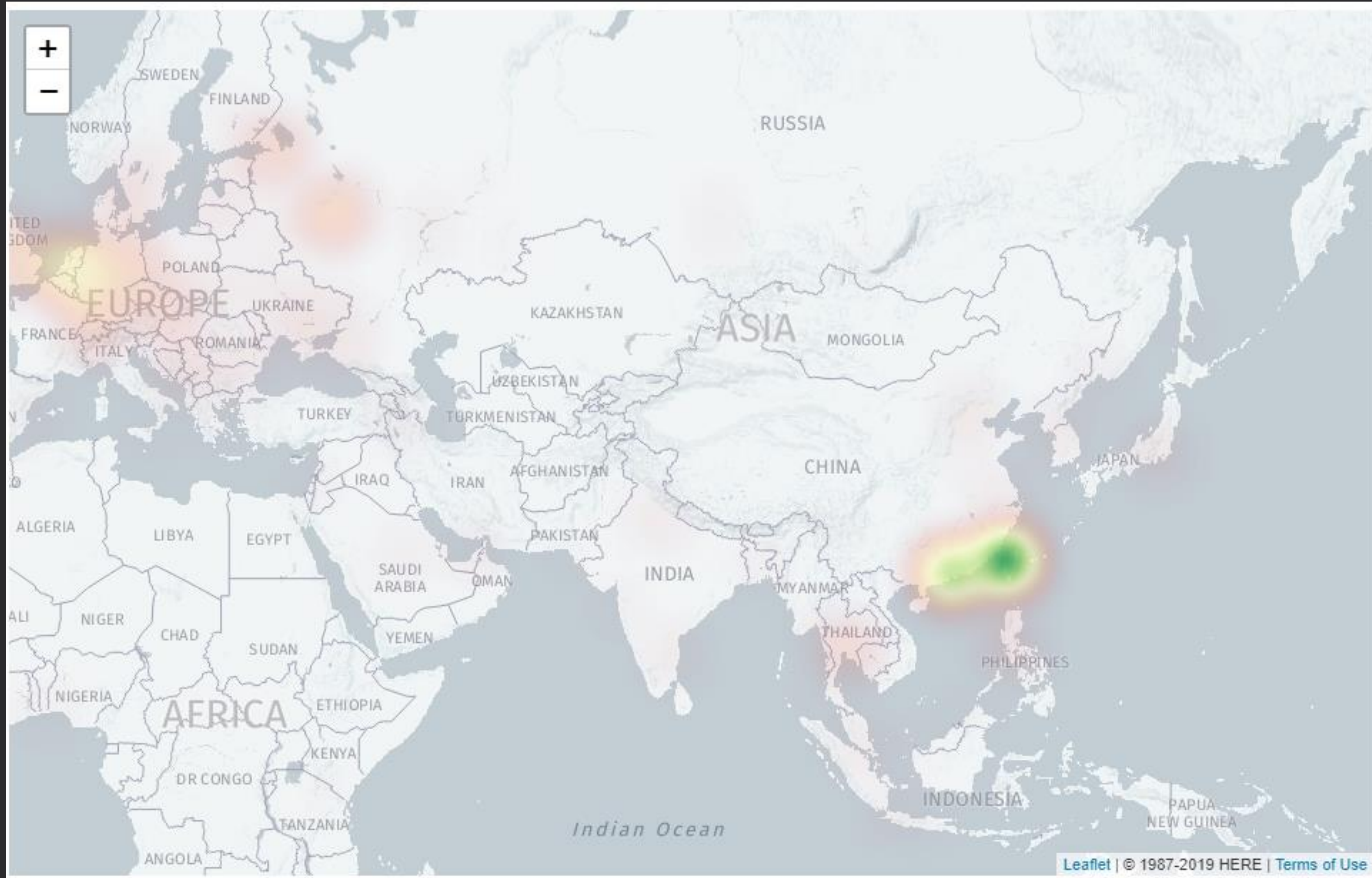


getting to know you

where are you from?

Probes and WIGLE.net

This info is based on probe requests captured during DEFCON and then searching those using the Wigle API.

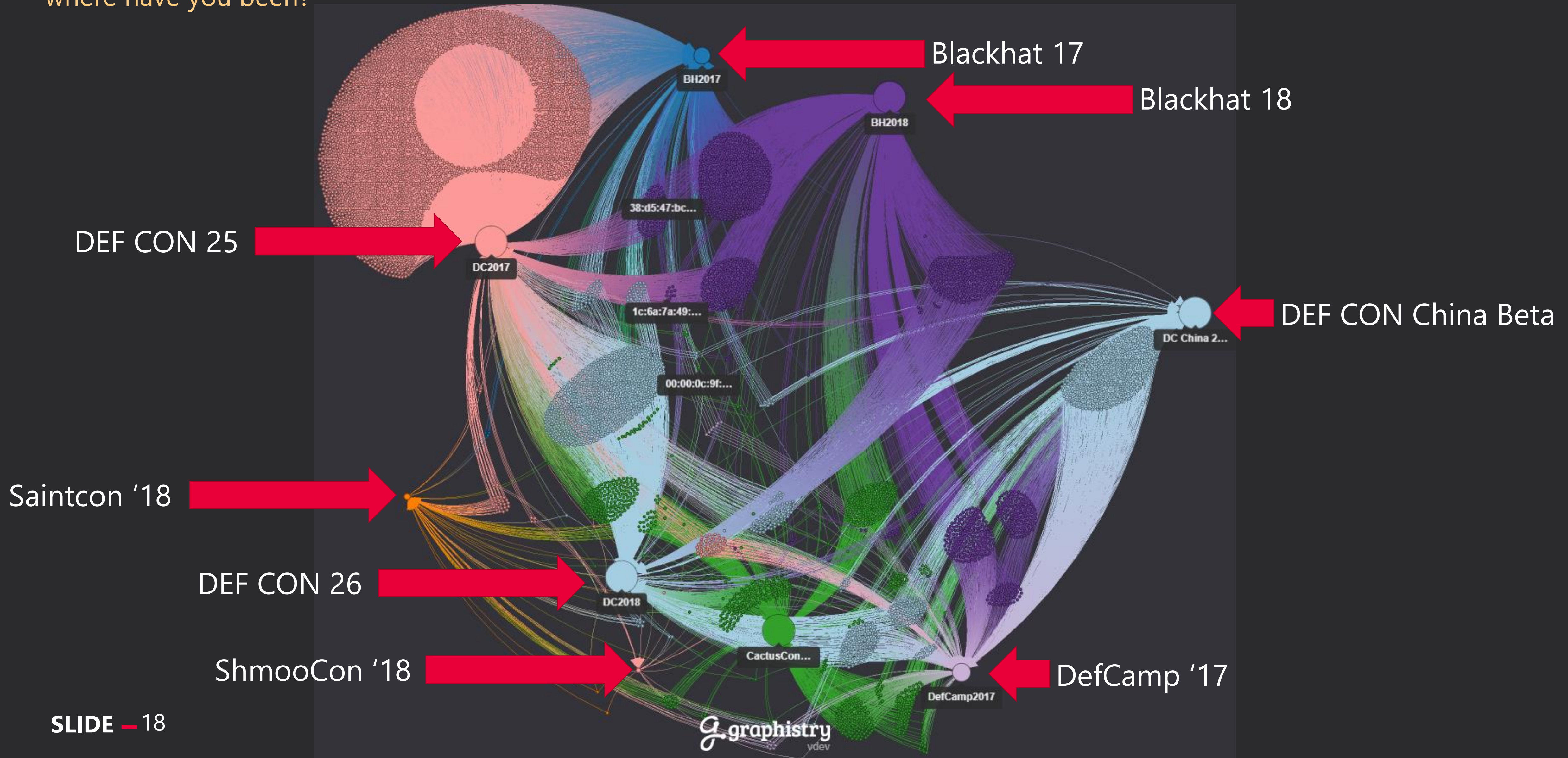


getting to know you

where have you been?

MAC Addresses and Where

This graph uses unique MAC addresses and knowing where the MAC address was seen at.



wireless attacks

its not all just pineapples

	MAC Address	Attack Type	OUI/Manufacturer	Notes
1	92:16:F9:9F:4D:08	Deauthentication	Unknown	Likely random MAC address, trying to DDOS or gather handshakes
2	07:7D:FD:FF:A1:A1	Deauthentication	Unknown	Likely random MAC address, trying to DDOS or gather handshakes
3	00:FF:A4:9F:FB:98	Deauthentication	Unknown	Likely random MAC address, trying to DDOS or gather handshakes
4	02:C0:CA:8D:A3:F4	KRACKS Attack	Unknown	Likely random MAC address, trying to break encryption
5	00:13:37:A6:16:8B	MiTM/Karma	Hak5	Pineapple doing pineapple things. At least 50 other Pineapples were seen as well.
6	AE:5F:3E:64:7F:0A	SSID bigger than 32 bytes	Unknown	Something fishy is going on here with the SSID

Kismet IDS Provided These Alerts

Thanks to the built in Intrusion Detection System in Kismet, it is able to identify these threats and log them to the Kismet database. This is a small sampling of common wireless threats in the environment.

wall of sheep?

not really, but here's some probably fake creds

	Server	Protocol	Username	Password
1	37.97.160.12 (hotdog.net)	HTTP	bomb	8=***
2	136.160.88.139 (usna.edu)	HTTP	dadmin010	PS2YS65*****
3	23.56.119.46 (samsung.com)	HTTP	highspeed2	HCMRX2*****
4	161.170.244.20 (walmart.com)	HTTP	leviton4	XOAEJLU*****
5	70.120.194.95 (austin.0x.no)	HTTP	NationalShitpostingAgency	NSA*****
6	133.242.149.131 (perorist.win)	HTTP	peropero	perop*****
7	23.38.226.56 (xfinity.com)	HTTP	surt8	U0Z69L8Y*****
8	64.137.180.143	HTTP	***** will help build Trump's wall	F87ef*****
9	211.251.140.134	SNMPv1	SNMP Community	public

data leaks

sharing is caring!

App API's using HTTP

Found in the DEFCON 25 dataset this API leaks location information potentially from a weather app showing sunrise info on a mobile device. The app could have trusted access to location data and shares it with anyone listening.

Host: www.met.no

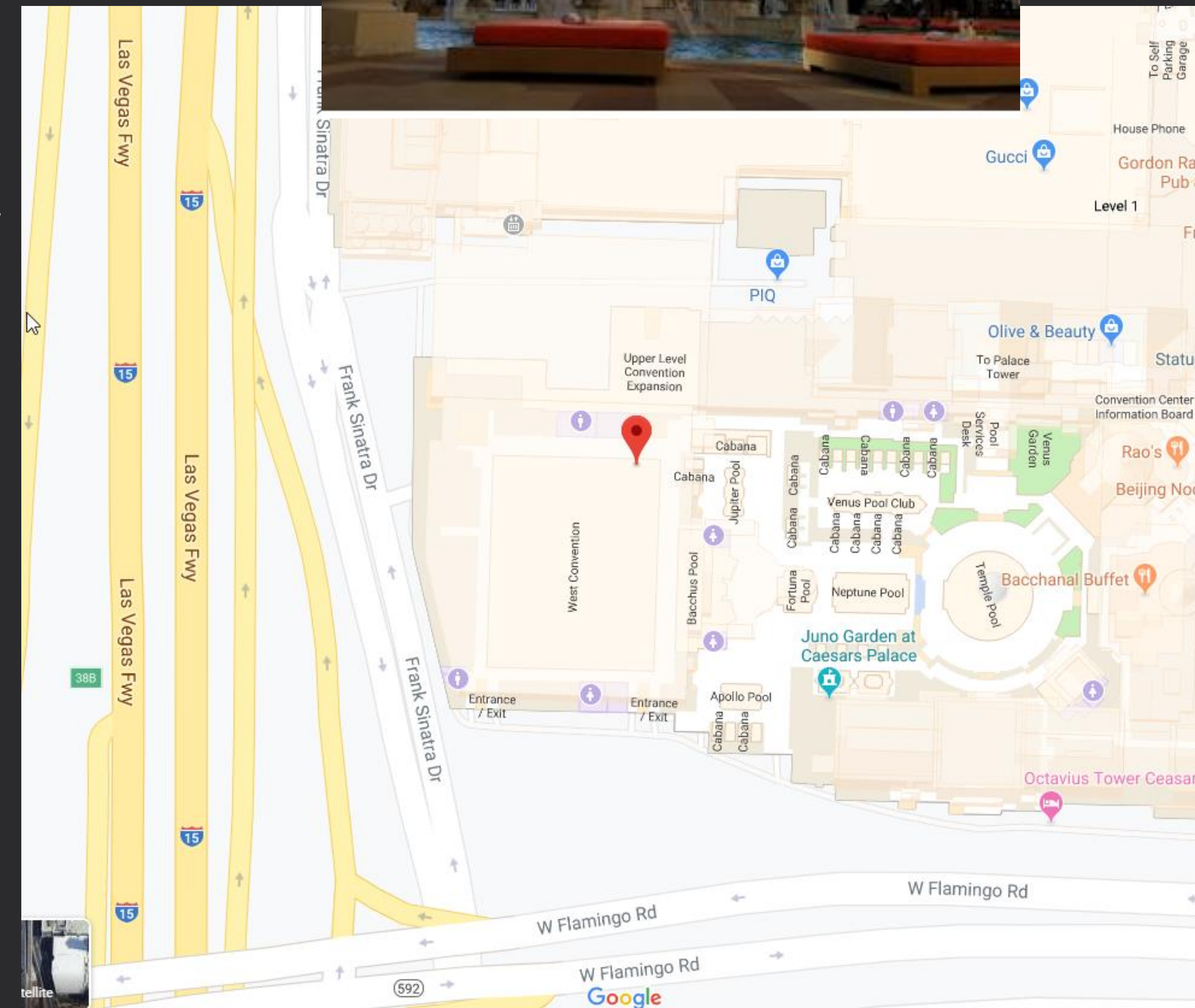
API Call:

<http://api.met.no/weatherapi/sunrise/1.1/?lat=36.1164&lon=-115.1785&date=2018-08-11>

Lat/Lon: 36.1164,-115.1785

API still accepts HTTP requests today but was updated a little:

<http://api.met.no/weatherapi/sunrise/2.0/?lat=36.1164&lon=-115.1785&date=2018-08-11&offset=-08:00>



data leaks

sharing is caring!

App API's using HTTP

Found in the DEFCON 26 dataset this API leaks location information from a ZTE Desktop Widget using Accu-Weather which likely has privileged access to location data on your phone.

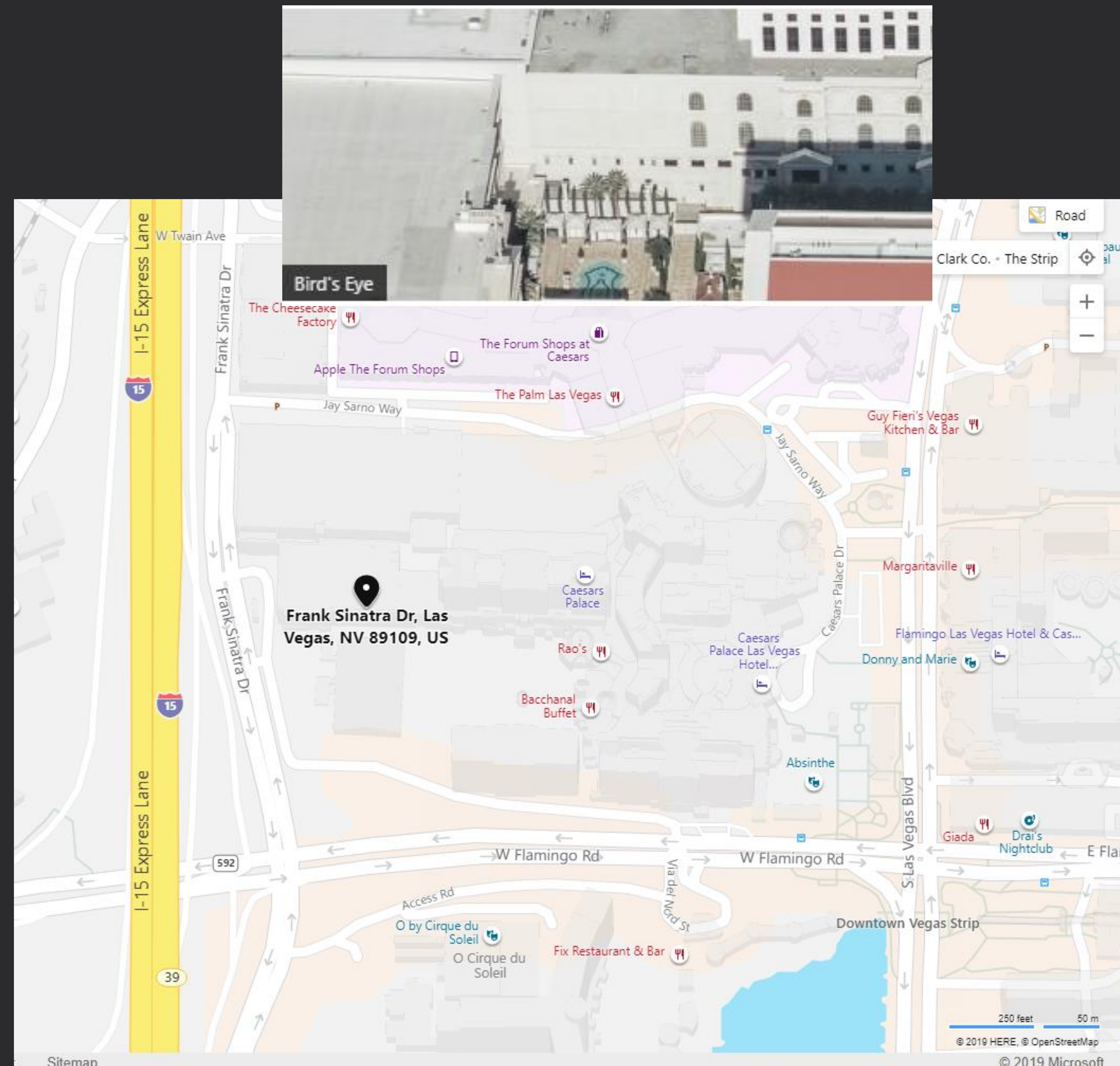
Host: accu-weather.com

Device: Android

API Call: <http://ztedesktopwidget.accu-weather.com/widget/ztedesktopwidget/weather-data.asp?slat=36.11675439&slon=-115.1785>

Lat/Lon: 36.11675439,-115.1785

Currently still using HTTP for the API.



data leaks

sharing is caring!

Alienware Bloatware

Found in the DEFCON 26 dataset this API call leaks your Alienware laptop serial number and OS version.

Host: content.dellsupportcenter.com

Device: Windows 10 Build 6.0.6992.1236

API Call:

<http://content.dellsupportcenter.com/mstr/pd.txt?pr=Alienware%2017%20R3&os=Win%2010%20%2817134.165%29&build=6.0.6992.1236&up=true&serial=9RN1462&id=4997f137-e883-45e2-9714-50d5f2c4c45b&dl=true&saaver=2.2.3.2&wr=1%2F20%2F2017%2012%3A00%3A00%20AM>

Warranty Status: Expired Jan 20, 2017



random sample of dns

DNS is typically unencrypted

The listed domains had DNS queries that were passed in the clear. If the website is using encryption no other information beyond DNS was gathered.

	ALL YOUR DNS...	
www.myspace.com	www.privateinternetaccess.com	www.finaid.caltech.edu
voyzwhpwt.coxhn.net (x1k)	tracker-api.my.com	tracking.optimatic.com
track.eyevewads.com	digitaltarget.ru	pixel.*.com (x50)
splunkoxygen.com	eb3dba18c25854f62ed2c3b5e73cd97a.0001abf0.iot.dc.org	cdn.*.com (x5k)
www.pornhub.com	wifiprotect.mcafee.com	api.*.com (x5k)
www.pjrc.com	www.wifipineapple.com	f*ckinghomepage.com
teamviewer.com	abercrombie.com	ads.*.com

i heard you like **slack**

DNS is typically unencrypted

Thanks to Slack using subdomains we can find out about all of the secret
slacks people are using at DEFCON.

	SLACK FTW	
0xproject.slack.com	def0x.slack.com	operationona.slack.com
2018defconwork.slack.com	files.slack.com	rbs-interns.slack.com
avtokyo.slack.com	ic3ethereum.slack.com	redballoonsecurity.slack.com
blockchainedu.slack.com	infosecboston.slack.com	seccon2016noc.slack.com
cohort-x-corp.slack.com	mohikan.slack.com	sfs-csusb.slack.com
consensys.slack.com	muckrock.slack.com	spamandhex.slack.com
darksite26.slack.com	openzeppelin.slack.com	status-im.slack.com

findings summary

what i've learned

DEFCON is truly a global community

DEAUTH's will happen

PINEAPPLES are a thing

API's will leak

IT WAS DNS (MYSPACE?????)

Hackers like Slack for some reason

Don't believe the HYPE, looking at you broadpwn

countermeasures **protection**

knowing is half the battle!



DO NOT AUTO-CONNECT

Do not enable auto-connect when connecting to an open Wireless Network! Delete networks from your devices that you are not going to continue to connect to!

USE A VPN

VPN services are cheaper and easier to use now than ever. You can get one that has an app on your device that will enable you to easily enable it when you are on an untrusted network.

USE 4G*/5G INSTEAD

Using data over cell networks should reduce your risk and coupling it with a VPN on top will make it even better.

*New research about 4G vulnerabilities is due to be released stay tuned for updates and panic.

thank you

this project could have not been possible without so many of you!



DEFCON

thank you for giving me the
inspiration to keep being
curious!



HAK5

huge thank you to everyone
at hak5 who've been
supportive from the
beginning!



KISMET

huge thank you to dragorn!
without kismet this project
wouldn't have been possible!



SAINTCON

the conference that gave me
the confidence to keep
presenting!



DC801

greetz and thank you to all of
the supportive utah hackers
who have always been there
for me!



NETWORKMINER

thank you to Netresec for
giving me access to their
awesome software!



GRAPHISTRY

thank you for solving big data
visualization problems and
providing me access to your
API!



WIGLE.NET

thank you for creating an
awesome war driving app and
sharing the data with the
world!

thank **you**

this project could have not been possible without so many of you!

HUGE **THANK YOU** TO EACH OF **YOU**
HERE AND ONLINE THAT
CONTINUALLY **SUPPORT ME!**

you are the inspiration that keeps me innovating and building late into the night!

the end



@d4rk**m4tter**



github.com/mspicer/**pcapinator**

pals**hack.org**



@d4rk**m4tter_**



bit.ly/**2OkdYz2**